A Large-Scale Empirical Study of Secret Leakage in Hugging Face Spaces

Anonymous Author(s)

Abstract

Hugging Face Spaces (Spaces) has become a leading platform for hosting AI applications, offering developers seamless integration of Git-based repositories and out-of-the-box web service deployment. However, as its adoption continues to expand, security concerns have come to light. Recent reports have pointed to the issue of accidental exposure of sensitive information, such as API tokens and database credentials, within Spaces-hosted code. Despite these concerns, the research community still lacks a comprehensive understanding of the scope and impact of these security risks. To bridge this gap, we present the first large-scale and systematic empirical study to quantify the extent of secret leakage in Spaces. We begin by compiling a comprehensive dataset of 313,647 public Spaces repositories created between March 2022 and December 2024. To detect exposed secrets, we introduce Secret Reviewer, an advanced framework that combines static analysis and Large Language Model (LLM)-assisted detection to identify leaked credentials. Applying Secret Reviewer, we identified 9,149 with secret leakage vulnerabilities and 11,557 unique keys—76% of which from leading AI service providers such as OpenAI and Groq. Our findings indicate that 30% of leaks were embedded in commit histories, and over 1,000 non-code files contained sensitive data. Further validation revealed that 30% of detected keys remained active, including 140 valid database credentials and 50% of API tokens with write permissions, underscoring significant security risks. Our study sheds light on critical security challenges in AI platform ecosystems and advocates for stronger security practices to mitigate these risks.

Keywords

Secret leakage, Security, Privacy, Hugging Face Spaces

ACM Reference Format:

Anonymous Author(s). 2018. A Large-Scale Empirical Study of Secret Leakage in Hugging Face Spaces. In *Proceedings of Make sure to enter the correct conference title from your rights confirmation email (Conference acronym 'XX).* ACM. New York, NY, USA, 11 pages. https://doi.org/XXXXXXX.XXXXXXX

1 Introduction

With the rapid advancement of artificial intelligence (AI) applications, the demand for convenient and scalable deployment solutions has increased significantly[30]. Hugging Face Spaces (hereafter referred to as Spaces) has emerged as a leading platform for hosting AI applications, providing developers with an efficient and user-friendly environment for quickly deploying and sharing AI models. By leveraging Git-based code repositories and built-in web service deployment, Spaces enables developers to build and showcase AI applications at minimal cost. As of now, Spaces has hosted more than 300,000 public AI web applications, forming a highly efficient AI service pipeline (as illustrated in Figure 1). Through standardized API interfaces, developers can seamlessly integrate third-party model inference services to perform AI tasks such as text generation and image recognition, without the need for complex computing resource management or extensive code adaptation.

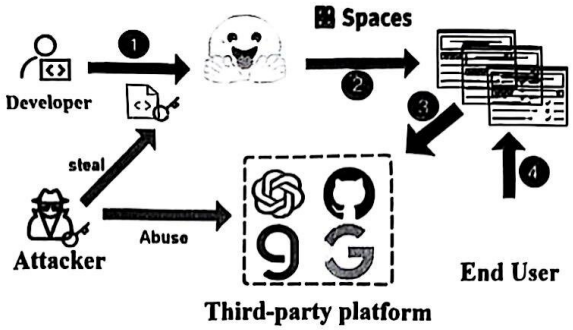

Figure 1: When developers use Spaces, they first create a repository and upload their code to the platform ❶. Subsequently, Spaces deploys and distributes the code based on its contents ❷. In addition to accessing the hosted large language models (LLMs) through API calls, developers can also leverage both Hugging Face and third-party cloud inference APIs ❸. Finally, end-users can interact with various AI applications via web interfaces ❹. However, if user inadvertently hardcodes secrets in a public Space, attackers can exploit them, leading to API abuse and privacy breaches.

However, this convenience also introduces serious security risks. Recent reports[7, 26] have revealed that a large number of API access tokens, database credentials, and other secret information have been inadvertently exposed in Spaces code repositories. Such exposures may lead to unauthorized API abuse, user data breaches, and even malicious code execution, posing a significant threat to the security of AI applications[15]. However, there is still a lack of systematic research on the issue of secret leakage in the Spaces platform. Compared to other code hosting platforms, secret leakage in Spaces may present several distinct security challenges: (1) Since Spaces focuses on AI applications and provides built-in web services, the volume, types, and file locations of leaked secrets may differ significantly from those observed on traditional platforms such as GitHub and GitLab. (2) The rapid expansion of the Spaces ecosystem may have led to inadequate secret detection and protection mechanisms in its early stages, resulting in variations in the

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
Conference acronym 'XX, Woodstock, NY
© 2018 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM ISBN 978-1-4503-XXXX-X/2018/06
https://doi.org/XXXXXXX.XXXXXXX